

NIS2 ve ISO 27001 Karşılaştırması — Yönetici Özeti

Proje: GD-PMS (Power Management System) **Versiyon:** 1.0 **Hedef Kitle:** Üst Yönetim, Ortaklar, Karar Vericiler **İlgili Dokümanlar:** [NIS2 Teknik Rehber](#), [ISO 27001 Teknik Rehber](#)

Bu belge, GD-PMS yazılımının satış ve işletme sürecinde karşılaşılabilecek iki bilgi güvenliği standardının — NIS2 Direktifi ve ISO/IEC 27001:2022 — yönetici seviyesinde karşılaştırmasını, organizasyonel etkilerini ve maliyet analizini içerir. Teknik uygulama detayları için ilgili teknik rehber dokümanlarına başvurulmalıdır.

1. Yönetici Özeti

GD-PMS bir enerji yönetim sistemi olarak Avrupa Birliği'ndeki enerji şirketlerine satılacaktır. Bu hedef kitle iki bilgi güvenliği gerekliliğiyle karşıımıza çıkmaktadır:

- NIS2 Direktifi:** AB'nin kritik altyapı sektörleri için getirdiği **yasal zorunluluk**. Enerji sektörü bu kapsamda. Müşterileriniz NIS2'ye uymak zorunda ve tedarikçilerinden de uyumluluk kanıtı talep edecekler. Sertifika değil, uygunluk değerlendirmesi. Yaptırımı: AB üyesi ülkelerde idari para cezası.
- ISO 27001:2022:** Uluslararası bilgi güvenliği yönetim sistemi standardı. **Gönüllü** ama globalde en yaygın bilgi güvenliği sertifikası. Akredite kuruluşlarca belgelendiriliyor, dünya çapında 70.000'den fazla kuruluş sertifikalı. İhalelerde ön koşul, kurumsal prestij göstergesi.

Stratejik öneri: GD-PMS için her ikisinin de uygulanması. Teknik altyapı büyük ölçüde ortak olduğu için ayrı ayrı yapmaya kıyasla **%30-35 daha düşük maliyetle** her iki standardın gereklilikleri karşılanabilir. AB müşterilerine NIS2 uyumluluğu kanıtlanırken, global pazarda ISO 27001 sertifikasıyla rekabet avantajı elde edilir.

2. NIS2 vs ISO 27001 — Temel Farklar

Kriter	NIS2 Direktifi	ISO/IEC 27001:2022
Türü	AB Direktifi — ulusal yasalara dönüşür	Uluslararası standart — gönüllü
Yasal statü	AB üyesi ülkelerde kanun	Gönüllü (ancak sözleşmelerde zorunlu tutulabilir)
Kapsam	Enerji, ulaşım, sağlık, dijital altyapı gibi kritik sektörler	Tüm sektörler , her ölçekte kuruluş
Zorunlu mu?	AB'de kritik sektörler için evet	Hayır, ancak müşteri talep ederse ticari zorunluluk
Denetim	Ulusal otorite (NCA) onaylı uygunluk değerlendirmesi	Akredite belgelendirme kuruluşu tarafından denetim
Sertifika verilir mi?	Hayır — "Uygunluk Beyanı" düzenlenir	Evet — 3 yıl geçerli uluslararası sertifika

Kriter	NIS2 Direktifi	ISO/IEC 27001:2022
Yaptırım	İdari para cezası (ciroya bağlı, milyon € seviyesinde olabilir)	Sertifika askıya alma/iptal (ticari itibar kaybı)
Odak alanı	Teknik kontroller, olay raporlama, tedarik zinciri	Yönetim sistemi — PUKO döngüsü (sürekli iyileştirme)
Uluslararası tanınırlık	Sadece AB	Global — IAF tanınmalı, 150+ ülke
İhale değeri	AB enerji ihalelerinde ön koşul	Global ihalelerde puan avantajı , bazılarında ön koşul
Kontrol sayısı	Madde 21'de ~10 başlık	Annex A'da 93 kontrol
İç denetim zorunlu mu?	Hayır	Evet — yıllık iç denetim programı
Yönetim gözden geçirme	Yok	Evet — yıllık üst yönetim toplantısı
Güncelleme	Ulusal yasa takvimine bağlı	Standart revizyonu (5-7 yılda bir)

3. GD-PMS'de Şu Ana Kadar Tamamlananlar

Mevcut GD-PMS monorepo altyapısı, NIS2 ve ISO 27001'in teknik gerekliliklerinin büyük bölümünü halihazırda karşılamaktadır. Aşağıdaki tablo, yazılım tarafında tamamlanmış güvenlik önlemlerini göstermektedir:

Ağ ve İletişim Güvenliği

Önlem	Durum	Açıklama
HTTPS everywhere (TLS 1.2+)	✓	Tüm backend servisler, web frontend ve nginx reverse proxy TLS ile çalışıyor. Düz HTTP'ye otomatik 301 yönlendirmesi mevcut.
HSTS (HTTP Strict Transport Security)	✓	<code>max-age=63072000</code> ile tarayıcıya HTTPS zorunluluğu bildiriliyor.
WSS (güvenli WebSocket)	✓	Gerçek zamanlı telemetri akışı WSS protokolü üzerinden şifreli.
Güçlü cipher suite'ler	✓	Sadece ECDHE + AES128-GCM, eski ve zayıf cipher'lar kapalı.
Security headers	✓	CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy tüm endpoint'lerde aktif.
Rate limiting	✓	Global (100 req/dk), brute-force (5 login/dk), endpoint-spesifik sınırlamalar. Redis-tabanlı paylaşımlı sayaç.
Ağ segmentasyonu	✓	Frontend, backend ve database ağları Docker seviyesinde izole. Sadece nginx port 443 dış dünyaya açık.

Kimlik Doğrulama ve Yetkilendirme

Önlem	Durum	Açıklama
JWT tabanlı kimlik doğrulama	✓	jose kütüphanesi, HS256 algoritması, access + refresh token
Güvenli cookie yönetimi	✓	Refresh token: Secure, HttpOnly, SameSite=Strict. <code>__Host-</code> prefix'i.
RBAC (rol tabanlı erişim)	✓	4 rol (admin, teknik, boss, guest), route bazlı yetki kontrolü
Parola hash (bcrypt)	✓	<code>BunPasswordHasher</code> ile güvenli parola saklama
Brute-force koruması	✓	5 başarısız deneme → 15 dakika hesap kilitleme
Oturum zaman aşımı	✓	admin rolü için 15 dakika inactivity → otomatik çıkış

Kod Kalitesi ve Güvenlik Taraması

Önlem	Durum	Açıklama
SonarQube (SonarCloud)	✓	NIS2 Compliance profili, hard-coded secret taraması, Blocker/Critical ihlal engelleme
Quality Gate	✓	Blocker > 0, Critical > 0, Security Rating < A → build başarısız
Custom ESLint güvenlik kuralları	✓	<code>no-math-random</code> (crypto.getRandomValues zorunlu), <code>no-raw-console-log</code> (TamperEvidentLogger zorunlu), <code>require-parameterized-query</code> (SQL injection engelleme), <code>require-timeout</code> (sonsuz döngü engelleme)
Zod input validation	✓	Tüm API girdileri Zod şemalarıyla doğrulanıyor

Loglama ve İzleme

Önlem	Durum	Açıklama
TamperEvidentLogger	✓	Hash zincirli, değiştirilemez, JSON formatlı, SIEM uyumlu log altyapısı. Tüm backend servislerde aktif.
Audit log	✓	Admin giriş/çıkış, cihaz konfigürasyon değişikliği, setpoint güncellemesi audit seviyesinde loglanıyor.
VerifyChain	✓	Log bütünlüğü otomatik doğrulama (SHA-256 hash zinciri). Vitest testi mevcut.
Frontend audit hook	✓	<code>useAuditLog</code> hook'u ile tüm UI kritik işlemleri backend'e audit olarak iletiliyor.
Health check endpoint	✓	<code>GET /api/nis2/health</code> — log zincir bütünlüğü, DB bağlantısı, son audit, uptime, disk/bellek/CPU kapasitesi.

Önlem	Durum	Açıklama
Saat senkronizasyonu (NTP)	✓	Tüm container'lar aynı timezone, NTP offset loglara kaydediliyor.

Konteyner ve Altyapı Güvenliği

Önlem	Durum	Açıklama
Non-root kullanıcı	✓	Tüm Docker container'ları özel kullanıcı ile çalışıyor (root değil).
Read-only rootfs	✓	Container dosya sistemi salt okunur, sadece gerekli izinler tmpfs.
Capability dropping	✓	<code>cap_drop: ALL</code> , sadece <code>NET_BIND_SERVICE</code> eklenmiş.
no-new-privileges	✓	Container içinde yetki yükseltme engellenmiş.
Environment secrets	✓	Hassas değerler GitHub Secrets'ta, <code>.env</code> dosyaları <code>.gitignore</code> 'da, docker-compose'da hard-coded değer yok.
Pre-commit hook	✓	<code>.env</code> dosyalarının kazara commit edilmesini engelleyen kontrol.

Test ve CI/CD

Önlem	Durum	Açıklama
Vitest birim test çerçevesi	✓	Tüm paketlerde kullanılabilir. <code>@nis2-security</code> ve <code>@iso27001</code> tag'li testler mevcut.
Playwright E2E test çerçevesi	✓	Güvenlik senaryoları (yetkisiz erişim, audit log, health check, security headers) otomasyonda.
GitHub Actions CI/CD	✓	Otomatik test, build, SonarQube taraması. <code>sonar.qualitygate.wait=true</code> .

4. Eksik Kalanlar

Tamamlananlar güçlü bir altyapı sağlasa da, her iki standart için hala yapılması gereken işler bulunmaktadır. Bunlar üç kategoriye ayrılır: yazılım, dokümantasyon ve dış kaynak.

NIS2 İçin Kalanlar

#	Eksik	Türü	Tahmini Süre	Sorumlu
N1	SBOM üretim ve Trivy CVE taraması (CI pipeline)	Yazılım	1-2 hafta	DevOps
N2	Playwright güvenlik E2E testlerinin genişletilmesi	Yazılım	2-3 hafta	QA / Geliştirici

#	Eksik	Türü	Tahmini Süre	Sorumlu
N3	Otomatik Sürüm Güvenlik Beyanı scripti	Yazılım	1 hafta	Geliştirici
N4	SSDF (Güvenli Geliştirme Politikası) belgesi	Dokümantasyon	1 hafta	Güvenlik Mimarı
N5	NIS2 uygunluk denetimi (gap analysis + audit)	Dış kaynak	2-4 hafta	Danışman firma
N6	Yıllık harici pentest sözleşmesi	Dış kaynak	1 hafta (sözleşme)	Yönetim

NIS2 için toplam kalan süre: 2-3 ay (yazılım + dokümantasyon) + denetim takvimi.

ISO 27001 İçin Kalanlar

#	Eksik	Türü	Tahmini Süre	Sorumlu
I1	ISMS dokümantasyon paketi (11+ politika ve prosedür)	Dokümantasyon	4-6 hafta	BGYS Temsilcisi + Danışman
I2	Varlık envanteri	Dokümantasyon	1 hafta	BGYS Temsilcisi
I3	Risk değerlendirme ve risk işleme planı	Dokümantasyon	2 hafta	BGYS Temsilcisi + Danışman
I4	Uygulanabilirlik Bildirgesi (SoA) — 93 kontrol	Dokümantasyon	1 hafta	BGYS Temsilcisi
I5	Erişim kontrol matrisi (mevcut RBAC ile uyumlu)	Dokümantasyon	3 gün	Güvenlik Mimarı
I6	Yedekleme otomasyon scripti (TimescaleDB + Redis)	Yazılım	1 hafta	Sistem Yöneticisi
I7	Olay müdahale prosedürü	Dokümantasyon	1 hafta	BGYS Temsilcisi
I8	İş sürekliliği planı (BCP)	Dokümantasyon	1 hafta	BGYS Temsilcisi
I9	Tedarikçi güvenlik değerlendirme form ve süreci	Dokümantasyon	3 gün	BGYS Temsilcisi
I10	Personel farkındalık eğitim programı	Süreç	1 hafta (hazırlık)	İK + BGYS Temsilcisi
I11	Gizlilik sözleşmesi (NDA) şablonu	Dokümantasyon	1 gün	Hukuk
I12	İç denetim programı ve prosedürü	Dokümantasyon	3 gün	BGYS Temsilcisi
I13	Yönetim gözden geçirme toplantı prosedürü	Dokümantasyon	2 gün	BGYS Temsilcisi

#	Eksik	Türü	Tahmini Süre	Sorumlu
I14	ISO standart dokümanı satın alma (27001 + 27002)	Satın alma	1 gün	Yönetim
I15	Stage 1 denetimi (dokümantasyon incelemesi)	Dış kaynak	1-3 gün	Belgelendirme kuruluşu
I16	Stage 2 denetimi (saha denetimi)	Dış kaynak	2-5 gün	Belgelendirme kuruluşu
I17	Pre-audit hazırlık kontrolü	Dış kaynak	1 gün	Danışman

ISO 27001 için toplam kalan süre: 3-4 ay (dokümantasyon + süreç) + 6-10 ay (denetim takvimi, Stage 1 ile Stage 2 arası 1-2 ay bekleme süresi dahil).

NIS2 + ISO 27001 Birlikte — Kalanların Ortaklaştırılması

Aşağıdaki işler her iki standart için de gereklidir ve bir kez yapılması yeterlidir:

İş	NIS2	ISO 27001	Birlikte Süre
Yazılım geliştirme kalan işleri (SBOM, E2E testleri, yedekleme scripti)	✓	✓	3-4 hafta
Dokümantasyon (SSDF + ISMS paketi)	1 hafta	4-6 hafta	5-7 hafta (birlikte)
Pentest	✓	✓	1 kez, birleşik kapsam
Danışmanlık	✓	✓	Tek danışman, birleşik proje

5. Organizasyonel Gereksinimler

Her iki standardın da şirket organizasyonuna getirdiği yükümlülükler vardır. ISO 27001 bu konuda NIS2'den belirgin şekilde daha kapsamlıdır.

Roller ve Sorumluluklar

Rol	Sadece NIS2	ISO 27001	Açıklama
BGYS Temsilcisi (ISMS Manager)	Gerekmez	Zorunlu	ISMS'in kurulumu, sürdürülmesi, iç denetim koordinasyonu, yönetim gözden geçirme raporlaması. Mevcut ekipten bir kişiye ek görev olarak verilebilir veya yarı zamanlı bir pozisyon açılabilir.
Güvenlik Mimarı	Önerilir	Önerilir	Güvenlik mimarisi, SonarQube profil yönetimi, pentest koordinasyonu, kod inceleme. Mevcut lead developer

Rol	Sadece NIS2	ISO 27001	Açıklama
(Security Lead)			veya senior developer bu rolü üstlenebilir.
Sistem Yöneticisi	Önerilir	Zorunlu	Altyapı güvenliği, yedekleme, erişim kontrolü, TLS sertifika yönetimi.
Üst Yönetim	Sınırlı	Aktif katılım	ISO 27001'de üst yönetimin yıllık YGG toplantısına katılması, kaynak tahsisi yapması, politikayı imzalaması zorunludur.
İç Denetçi	Gerekmez	Zorunlu	ISO 27001 İç Denetçi eğitimi almış, kendi alanını denetlemeyen bir kişi. Dışarıdan danışman olarak da alınabilir.
Tüm Personel	Farkındalık önerilir	Zorunlu	Yıllık bilgi güvenliği farkındalık eğitimi. İşe girişte NDA imzalama.

Düzenli Toplantı ve Faaliyetler

Faaliyet	Sıklık	NIS2	ISO 27001
Yönetim Gözden Geçirme (YGG)	Yılda 1	Gerekmez	Zorunlu (üst yönetim katılımlı)
İç Denetim	Yılda 1-2	Gerekmez	Zorunlu
Varlık envanteri güncelleme	Yılda 1 + büyük değişiklik	Gerekmez	Zorunlu
Risk değerlendirme	Yılda 1 + büyük değişiklik	Önerilir	Zorunlu
Tedarikçi değerlendirme	Yılda 1	Gerekmez	Zorunlu (kritik tedarikçiler)
Personel farkındalık eğitimi	Yılda 1	Önerilir	Zorunlu
Olay müdahale tatbikatı	Yılda 1	Önerilir	Zorunlu
BCP / yedekten dönme tatbikatı	Yılda 1	Gerekmez	Zorunlu
Harici pentest	Yılda 1	Önerilir	Zorunlu
Sertifikasyon gözetim denetimi	Yılda 1 (Yıl 2, 3)	Gerekmez	Zorunlu

Organizasyonel Yük Özeti

	NIS2	ISO 27001
Ek personel ihtiyacı	Yok (mevcut ekip yeterli)	1 kişi BGYS Temsilcisi (mevcut ekibe ek görev veya yarı zamanlı)
Üst yönetim zamanı	Yılda 2-4 saat (rapor okuma)	Yılda 8-16 saat (YGG hazırlık + toplantı)

	NIS2	ISO 27001
Yıllık zorunlu faaliyet sayısı	1 (pentest)	8+ (pentest, iç denetim, YGG, eğitim, tatbikatlar, vb.)
Doküman sayısı	2-3 (SSDF, pentest raporu)	15-20 (politika, prosedür, plan, kayıt)

6. Maliyet Analizi (Detaylı)

Aşağıdaki tüm rakamlar **geliştirme işçiliği hariçtir**. Harici hizmet, lisans, eğitim ve sertifikasyon maliyetlerini kapsar.

6.1 Senaryo A — Sadece NIS2

#	Kalem	Periyot	EUR (min-max)	TL (min-max)	Zorunluluk
A1	NIS2 uygunluk danışmanlığı (gap analysis + uyumluluk yol haritası)	Tek seferlik	€8.000 – €20.000	₺320.000 – ₺800.000	Önerilen
A2	NIS2 uygunluk denetimi (conformity assessment) — akredite firma	Tek seferlik	€5.000 – €15.000	₺200.000 – ₺600.000	Zorunlu
A3	Harici pentest (CREST/CHECK akredite, tüm servisler + uygulamalar)	Yılda 1	€10.000 – €25.000	₺400.000 – ₺1.000.000	Önerilen
A4	Trivy / Dependency-Track (açık kaynak, self-hosted)	Yıllık altyapı	€0 – €500	₺0 – ₺20.000	Zorunlu (araç ücretsiz)
A5	SIEM/log yönetim platformu (self-hosted ELK/Grafana Loki)	Yıllık altyapı	€0 – €2.000	₺0 – ₺80.000	Önerilen

NIS2 3 Yıllık Toplam Maliyet:

Yıl	Kalemler	EUR (min-max)	TL (min-max)
Yıl 1	Danışmanlık + Denetim + Pentest + Altyapı	€23.000 – €62.500	₺920.000 – ₺2.500.000
Yıl 2	Pentest + Altyapı	€10.000 – €27.500	₺400.000 – ₺1.100.000
Yıl 3	Pentest + Altyapı	€10.000 – €27.500	₺400.000 – ₺1.100.000
3 Yıl Toplam		€43.000 – €117.500	₺1.720.000 – ₺4.700.000

6.2 Senaryo B — Sadece ISO 27001

#	Kalem	Periyot	EUR (min-max)	TL (min-max)	Zorunluluk
B1	ISO danışmanlık — ISMS kurulum + dokümantasyon	Tek seferlik	€10.000 – €30.000	₺400.000 – ₺1.200.000	Önerilen
B2	Stage 1 denetimi (dokümantasyon incelemesi)	Tek seferlik	€2.000 – €5.000	₺80.000 – ₺200.000	Zorunlu
B3	Stage 2 denetimi (saha denetimi, sertifikasyon)	Tek seferlik	€4.000 – €12.000	₺160.000 – ₺480.000	Zorunlu
B4	Pre-audit check (Stage 2 öncesi hazırlık kontrolü)	Tek seferlik	€2.000 – €5.000	₺80.000 – ₺200.000	Önerilen
B5	Gözetim denetimi 1 (Yıl 2)	Yıl 2	€3.000 – €6.000	₺120.000 – ₺240.000	Zorunlu
B6	Gözetim denetimi 2 (Yıl 3)	Yıl 3	€3.000 – €6.000	₺120.000 – ₺240.000	Zorunlu
B7	Yeniden belgelendirme (Yıl 3 sonu)	3 yılda 1	€5.000 – €15.000	₺200.000 – ₺600.000	Zorunlu
B8	Harici pentest (CREST/CHECK akredite)	Yılda 1	€10.000 – €25.000	₺400.000 – ₺1.000.000	Zorunlu
B9	ISO standart dokümanı lisansı (27001 + 27002)	Tek seferlik	€250 – CHF 310	₺10.000 – ₺12.500	Zorunlu
B10	İç Denetçi eğitimi (1 kişi)	Tek seferlik	€1.000 – €2.000	₺40.000 – ₺80.000	Zorunlu
B11	Lead Implementer eğitimi (1 kişi)	Tek seferlik	€1.500 – €3.000	₺60.000 – ₺120.000	Önerilen
B12	Personel farkındalık eğitimi (platform aboneliği)	Yılda 1	€500 – €2.000	₺20.000 – ₺80.000	Zorunlu
B13	SIEM/log yönetim platformu	Yıllık	€3.000 – €15.000	₺120.000 – ₺600.000	Önerilen
B14	GRC platformu (Vanta/Drata/Scrut — sürekli uyumluluk)	Yıllık	\$5.000 – \$20.000	₺180.000 – ₺720.000	Önerilen

ISO 27001 3 Yıllık Toplam Maliyet:

Yıl	Kalemler	EUR (min-max)	TL (min-max)
Yıl 1	Danışmanlık + Stage 1 + Stage 2 + Pre-audit + Eğitimler + Lisans + Pentest + SIEM + GRC + Farkındalık	€37.250 – €105.310	₺1.490.000 – ₺4.212.500

Yıl	Kalemler	EUR (min-max)	TL (min-max)
Yıl 2	Gözetim 1 + Pentest + SIEM + GRC + Farkındalık	€19.500 – €63.000	₺780.000 – ₺2.520.000
Yıl 3	Gözetim 2 + Re-cert + Pentest + SIEM + GRC + Farkındalık	€24.500 – €73.000	₺980.000 – ₺2.920.000
3 Yıl Toplam		€81.250 – €241.310	₺3.250.000 – ₺9.652.500

6.3 Senaryo C — NIS2 + ISO 27001 Birlikte (Önerilen)

İki standardın birlikte uygulanması, ortak maliyetlerin birleştirilmesiyle önemli tasarruf sağlar. Teknik altyapı (SonarQube, TamperEvidentLogger, TLS, pentest) zaten ortaktır. Danışmanlık ve denetim de aynı firmayla birleştirilebilir.

#	Kalem	Periyot	EUR (min-max)	TL (min-max)	Not
C1	Birleşik danışmanlık (NIS2 + ISO gap analysis + ISMS kurulum)	Tek seferlik	€15.000 – €40.000	₺600.000 – ₺1.600.000	Ayrı ayrı €18K-50K yerine
C2	Stage 1 denetimi (ISO dokümantasyon)	Tek seferlik	€2.000 – €5.000	₺80.000 – ₺200.000	Zorunlu
C3	Stage 2 denetimi (ISO saha + NIS2 uygunluk birlikte)	Tek seferlik	€6.000 – €18.000	₺240.000 – ₺720.000	NIS2 assessment ISO denetimine ek olarak aynı firmaya
C4	Pre-audit check	Tek seferlik	€2.000 – €5.000	₺80.000 – ₺200.000	Önerilen
C5	Gözetim denetimi 1 (Yıl 2, ISO + NIS2 gözden geçirme)	Yıl 2	€4.000 – €8.000	₺160.000 – ₺320.000	Birleşik
C6	Gözetim denetimi 2 (Yıl 3, ISO + NIS2 gözden geçirme)	Yıl 3	€4.000 – €8.000	₺160.000 – ₺320.000	Birleşik
C7	Yeniden belgelendirme (ISO re-cert + NIS2 yenileme)	3 yılda 1	€6.000 – €18.000	₺240.000 – ₺720.000	Birleşik
C8	Harici pentest — birleşik kapsam (NIS2 + ISO gereksinimleri)	Yılda 1	€12.000 – €25.000	₺480.000 – ₺1.000.000	Ayrı ayrı 2x€15K-25K yerine tek pentest
C9	ISO standart dokümanı lisansı	Tek seferlik	€250 – CHF 310	₺10.000 – ₺12.500	Zorunlu

#	Kalem	Periyot	EUR (min-max)	TL (min-max)	Not
C10	İç Denetçi eğitimi (1 kişi)	Tek seferlik	€1.000 – €2.000	₺40.000 – ₺80.000	Zorunlu
C11	Lead Implementer eğitimi (1 kişi, birleşik NIS2+ISO)	Tek seferlik	€1.500 – €3.000	₺60.000 – ₺120.000	Önerilen
C12	Personel farkındalık eğitimi	Yılda 1	€500 – €2.000	₺20.000 – ₺80.000	Zorunlu
C13	SIEM/log yönetim platformu (ortak altyapı)	Yıllık	€3.000 – €15.000	₺120.000 – ₺600.000	Önerilen
C14	GRC platformu (Vanta/Drata/Scrut)	Yıllık	\$5.000 – \$20.000	₺180.000 – ₺720.000	Önerilen

NIS2 + ISO 27001 Birleşik 3 Yıllık Toplam Maliyet:

Yıl	Kalemler	EUR (min-max)	TL (min-max)
Yıl 1	Danışmanlık + Stage 1 + Stage 2 + Pre-audit + Eğitimler + Lisans + Pentest + SIEM + GRC + Farkındalık	€47.250 – €123.310	₺1.890.000 – ₺4.932.500
Yıl 2	Gözetim 1 + Pentest + SIEM + GRC + Farkındalık	€22.500 – €65.000	₺900.000 – ₺2.600.000
Yıl 3	Gözetim 2 + Re-cert + Pentest + SIEM + GRC + Farkındalık	€27.500 – €78.000	₺1.100.000 – ₺3.120.000
3 Yıl Toplam		€97.250 – €266.310	₺3.890.000 – ₺10.652.500

Not: Geliştirme işçilik maliyetleri bu tutarlara dahil değildir.

6.4 Üç Senaryonun Yan Yana Karşılaştırması

	Sadece NIS2	Sadece ISO 27001	İkisi Birlikte
Başlangıç (Yıl 1)	€23.000 – €62.500	€37.250 – €105.310	€47.250 – €123.310
Yıllık ortalama (Yıl 2-3)	€10.000 – €27.500	€22.000 – €68.000	€25.000 – €71.500
3 Yıllık Toplam	€43.000 – €117.500	€81.250 – €241.310	€97.250 – €266.310
Ayrı ayrı yapılsaydı toplam	—	—	€124.250 – €358.810

6.5 Birleşik Yapmanın Tasarrufu

Tasarruf Kaynağı	Ayrı Ayrı (A+B)	Birleşik (C)	Tasarruf
Danışmanlık	€18.000 – €50.000	€15.000 – €40.000	%17 – %20
Denetim paketi (3 yıl)	€22.000 – €62.000	€22.000 – €57.000	%0 – %8
Pentest (3 yıl)	€30.000 – €75.000	€36.000 – €75.000	Negatif — birleşik pentest kapsamı genişlediği için maliyet artabilir ancak ayrı ayrı 2 pentest yapmaktan %20-30 daha düşük
SIEM/Log platformu (3 yıl)	€9.000 – €51.000	€9.000 – €45.000	Aynı veya daha düşük (tek altyapı)
Eğitim (tek seferlik)	€3.000 – €7.000	€2.500 – €5.000	%17 – %29
Toplam 3 Yıllık Tasarruf			€27.000 – €92.500 (%22 – %26)

7. Zaman Çizelgesi

7.1 Aşama Süreleri

Aşama	Sadece NIS2	Sadece ISO 27001	İkisi Birlikte
Yazılım geliştirme (kalan işler)	3-4 hafta	1-2 hafta	3-4 hafta
Dokümantasyon	1-2 hafta	4-6 hafta	5-7 hafta
İç denetim (ISO zorunlu)	—	1 hafta	1 hafta
YGG hazırlık ve toplantı (ISO zorunlu)	—	1 hafta	1 hafta
Danışmanlık — gap analysis	2 hafta	2-3 hafta	2-3 hafta
Pre-audit	—	1 gün	1 gün
Stage 1 denetimi	—	1-3 gün	1-3 gün
Stage 1 bulgularının kapatılması	—	1-2 ay	1-2 ay
Stage 2 denetimi (ISO) + NIS2 uygunluk	1-2 gün	2-5 gün	3-7 gün
Toplam (başlangıçtan sertifikaya)	2-3 ay	6-10 ay	7-12 ay

7.2 Önerilen Zaman Çizelgesi (Senaryo C — Birlikte)

Ay	Faaliyet	Sorumlu
1. Ay	Yazılım kalan işlerinin tamamlanması (SBOM, E2E testleri, yedekleme scripti)	Geliştirme ekibi

Ay	Faaliyet	Sorumlu
2. Ay	ISMS dokümantasyon paketinin hazırlanması (politikalar, prosedürler, SoA)	BGYS Temsilcisi + Danışman
3. Ay	Risk değerlendirme ve işleme planı, varlık envanteri, erişim kontrol matrisi	BGYS Temsilcisi
4. Ay	İç denetim + Yönetim Gözden Geçirme toplantısı	BGYS Temsilcisi + Üst Yönetim
5. Ay	Stage 1 denetimi (belgelendirme kuruluşu)	Belgelendirme kuruluşu
6. Ay	Stage 1 bulgularının kapatılması	BGYS Temsilcisi + Geliştirme
7. Ay	Pre-audit check + harici pentest (birleşik kapsam)	Danışman + Pentest firması
8. Ay	Stage 2 denetimi + NIS2 uygunluk değerlendirmesi	Belgelendirme kuruluşu
9. Ay	ISO 27001 sertifikası + NIS2 uygunluk beyanı	

8. Riskler ve Fırsatlar

8.1 Hiçbirini Yapmamanın Riskleri

Risk	Olasılık	Etki	Açıklama
AB müşteri kaybı	Yüksek	Kritik	AB'deki enerji şirketleri NIS2 kapsamında tedarikçilerinden uyumluluk kanıtı talep etmek zorunda. Belgeniz yoksa satış yapamazsınız.
İhale dışı kalma	Yüksek	Yüksek	Global enerji ihalelerinde ISO 27001 sertifikası giderek ön koşul haline geliyor.
Rekabet dezavantajı	Orta	Yüksek	Rakipleriniz NIS2/ISO 27001 uyumluysa, siz değilseniz müşteri sizi seçmez.
Veri ihlali maliyeti	Düşük	Kritik	Güvenlik önlemleri olmadan yaşanacak bir ihlal hem maddi (tazminat) hem itibari kayba yol açar.
Yasal yaptırım (NIS2)	Düşük	Orta	GD-PMS Türkiye merkezli olduğu için doğrudan NIS2 cezası riski düşük, ancak AB müşterisi üzerinden dolaylı etkilenebilir.

8.2 Yapmanın Getirileri

Fırsat	Etki	Açıklama
AB pazarına giriş	Kritik	NIS2 uyumluluğu olmadan AB enerji sektörüne satış mümkün değil. Bu belge pazara giriş anahtarıdır.
Global rekabet avantajı	Yüksek	ISO 27001 sertifikası, GD-PMS'yi rakiplerinden ayıran bir güven işareti. İhalelerde puan avantajı sağlar.
Kurumsal prestij	Yüksek	ISO 27001, dünyada en saygın bilgi güvenliği sertifikasıdır. Müşteri güvenini ve marka değerini artırır.
Satış sürecinin hızlanması	Orta	Güvenlik due diligence sorularına "ISO 27001 sertifikamız var" cevabı, satış döngüsünü kısaltır.
Prim indirimi	Düşük-Orta	Siber güvenlik sigortası primlerinde ISO 27001 sertifikası olan şirketlere %10-30 indirim uygulanabilir.
Operasyonel disiplin	Orta	ISMS süreçleri (yedekleme, olay müdahale, iç denetim) yazılımın işletim kalitesini artırır, kesinti sürelerini azaltır.
Yatırımcı güveni	Orta	Yatırım turunda ISO 27001 sertifikası, şirketin profesyonel yönetildiğinin göstergesi olarak değerlendirilir.

8.3 Sadece NIS2 Yapıp ISO'yu Atlamanın Riskleri

- AB dışı pazarlarda (Orta Doğu, Asya, Kuzey Amerika) NIS2 tanınmaz. ISO 27001 global standarttır.
- NIS2 uygunluk raporu 2-3 yılda bir yenilenmeli; ISO sertifikası ise yıllık gözetimle sürekli güncel kalır.
- NIS2'de iç denetim, YGG, BCP gibi sürekli iyileştirme mekanizmaları yoktur — sadece anlık uygunluk gösterir.

9. Önerilen Yol Haritası

Stratejik Öneri: NIS2 + ISO 27001 Birlikte

Gerekçe:

- Teknik altyapının %80'i tamamlanmış durumda (bkz. Bölüm 3)
- İkisini ayrı ayrı yapmaya kıyasla %22-26 maliyet tasarrufu
- NIS2 AB pazarı için yasal zorunluluk, ISO 27001 global rekabet avantajı
- Aynı danışman ve aynı belgelendirme kuruluşuyla süreç yönetimi daha verimli

Önceliklendirme

Öncelik	Aksiyon	Zamanlama
P0 — Hemen	Kalan yazılım geliştirmelerinin tamamlanması (SBOM, E2E testleri, yedekleme)	1. Ay
P0 — Hemen	Danışmanlık firması seçimi ve sözleşme	1. Ay

Öncelik	Aksiyon	Zamanlama
P0 — Hemen	ISO 27001 + 27002 standart dokümanlarının satın alınması	1. Ay
P1 — 2-3. Ay	Danışman eşliğinde ISMS dokümantasyon paketinin hazırlanması	2-3. Ay
P1 — 3. Ay	Risk değerlendirme, varlık envanteri, erişim kontrol matrisi	3. Ay
P2 — 4. Ay	İç denetim, YGG, pre-audit check	4. Ay
P2 — 4. Ay	Personel farkındalık eğitimi (ilk tur)	4. Ay
P3 — 5-6. Ay	Stage 1 denetimi + bulgu kapatma	5-6. Ay
P3 — 7. Ay	Harici pentest (birleşik kapsam)	7. Ay
P4 — 8-9. Ay	Stage 2 denetimi + NIS2 uygunluk değerlendirmesi	8-9. Ay
Hedef	ISO 27001 sertifikası + NIS2 uygunluk beyanı	9. Ay

İlk 30 Günde Yapılması Gerekenler

- BGYS Temsilcisi ataması** — Mevcut ekipten bir kişi (örn. lead developer veya proje yöneticisi)
- Danışmanlık teklifi toplama** — En az 3 firmadan (tercihen hem NIS2 hem ISO 27001 tecrübeli)
- Belgelendirme kuruluşu araştırması** — BSI, TÜV, SGS'den teklif
- ISO standart dokümanı satın alma** — [ISO Store](#) üzerinden
- Kalan yazılım işlerinin sprint planlaması**

Ek: Küçük Bir Şirket İçin Bu İşin Gerçekçiliği

"ISO 27001 büyük şirketler için değil mi?" — ISO 27001:2022, özellikle KOBİ'ler düşünülerek sadeleştirildi. Standardın kendisi de "kuruluşun büyüklüğüne ve yapısına uygun" bir ISMS kurulmasını söyler. Önemli olan:

- 93 kontrolün hepsini uygulamak zorunda değilsiniz.** SoA'da uygulanmayan kontrolleri gerekçelendirmeniz yeterli. GD-PMS gibi yazılım odaklı bir şirkette fiziksel kontrollerin çoğu kapsam dışı bırakılabilir.
- ISMS dokümantasyonu abartılmak zorunda değil.** 20 sayfalık prosedürler yerine, işe yarayan, kısa ve uygulanabilir dokümanlar yeterli.
- GD-PMS'nin mevcut altyapısı için %50'sini halletmiş durumda.** GitHub Actions CI/CD, SonarQube, Docker, ESLint kuralları zaten çalışıyor. Bunların üzerine politika ve süreç katmanı ekleniyor.

Mevcut ekiple yürütülebilir mi? Evet. BGYS Temsilcisi rolü mevcut bir geliştiriciye yarı zamanlı ek görev olarak verilebilir. Danışman desteğiyle dokümantasyon 4-6 haftada tamamlanır. Sürecin en yoğun dönemi 2-3 aydır; sonrası yılda birkaç günlük rutin faaliyetlere dönüşür.

Bu belge, GD-PMS için NIS2 ve ISO/IEC 27001:2022 uyumluluk sürecinin yönetici seviyesinde değerlendirilmesi amacıyla hazırlanmıştır. Teknik uygulama detayları ve adım adım yol haritası için lütfen ilgili

teknik rehber dokümanlarına başvurunuz.